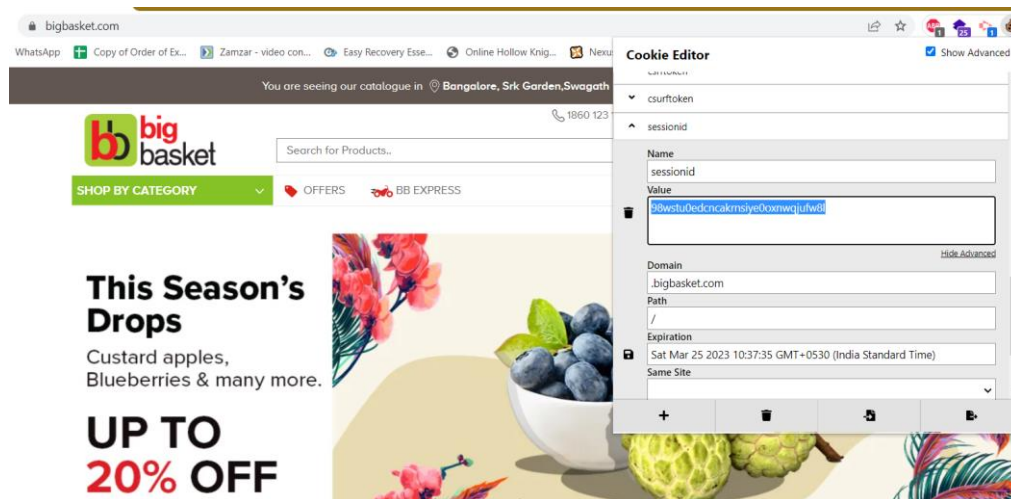


MINOR PROJECT 2

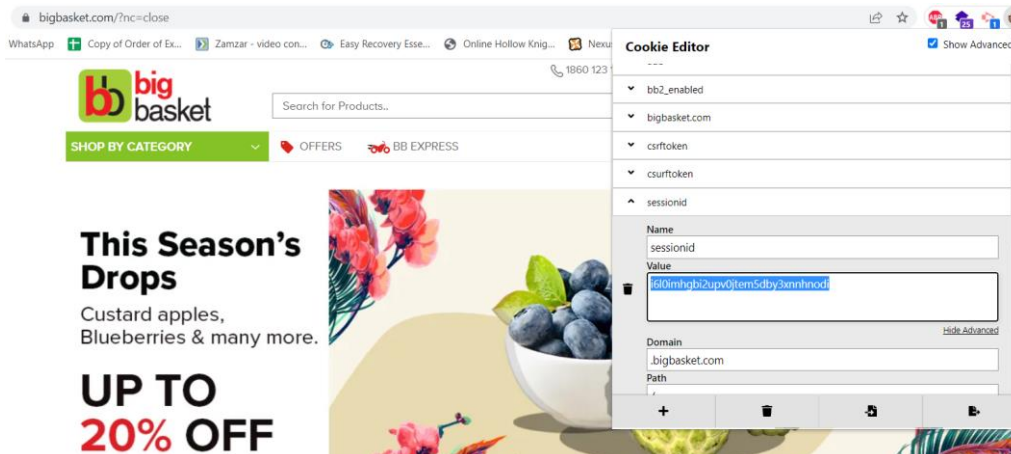
Target URL – bigbasket.com

1. Session Fixation vulnerability

Session ID Before login -



Session ID After login -



Result: Session IDs before and after login are different. No vulnerability found.

2. Session replay vulnerability

Session ID after login -

The screenshot shows the BigBasket website interface. The main banner features the 'esho! live Healthy' logo and the text 'Premium Tender Coconut' with '10 ml of pure freshness'. A 'Cookie Editor' window is open on the right, displaying the 'sessionid' cookie. The cookie details are as follows:

Name	Value	Domain	Path	Expiration
sessionid	1610mhgbi2upv0item5dby3xnnhndi	.bigbasket.com	/	Sat Mar 25 2023 10:33:18 GMT+0530 (India Standard Time)

Session ID after logout -

The screenshot shows the BigBasket website interface after a logout. The main banner is the same as the previous image. The 'Cookie Editor' window is open on the right, displaying the 'sessionid' cookie. The cookie details are as follows:

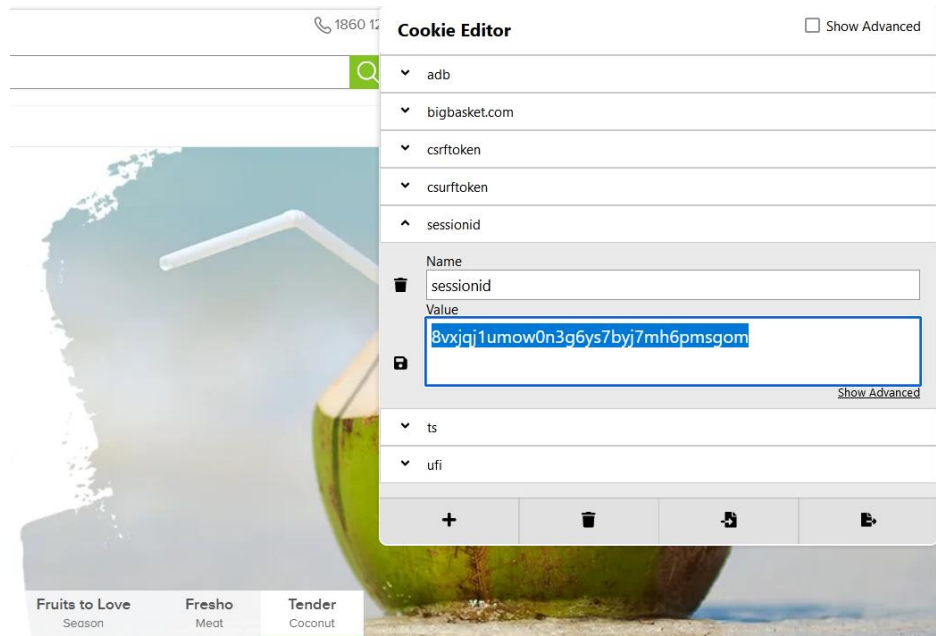
Name	Value	Domain	Path	Expiration
sessionid	mmiznoy21an15iy3fpdql6gt4y0j12q	.bigbasket.com	/	Sat Mar 25 2023 10:35:38 GMT+0530 (India Standard Time)

Result:

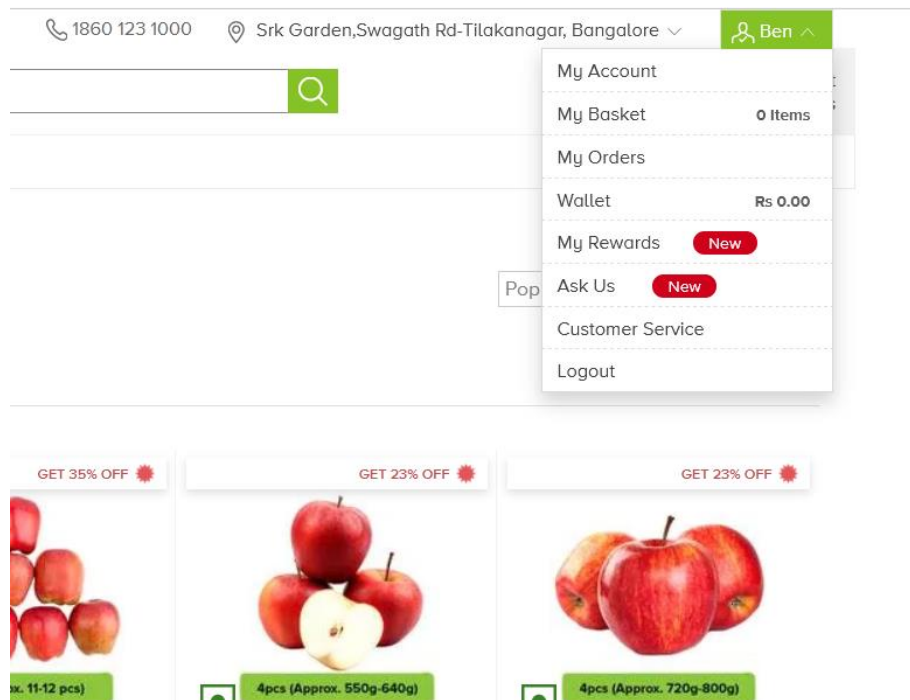
Session IDs after login and after logout are different. No vulnerability found.

3. Session Hijacking attack

Session ID from a logged in account has been copied and pasted into cookie editor -

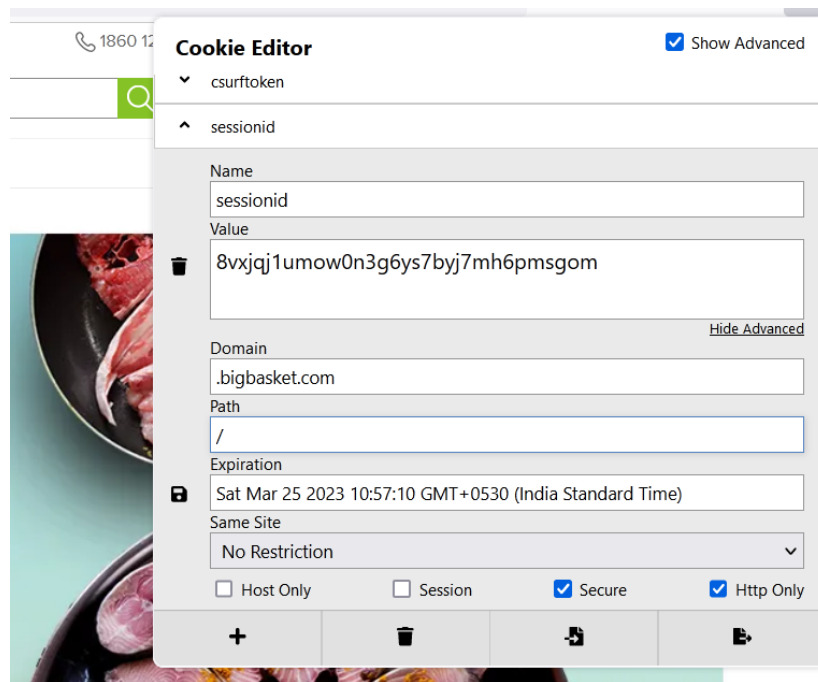


Account has been logged in using session ID -



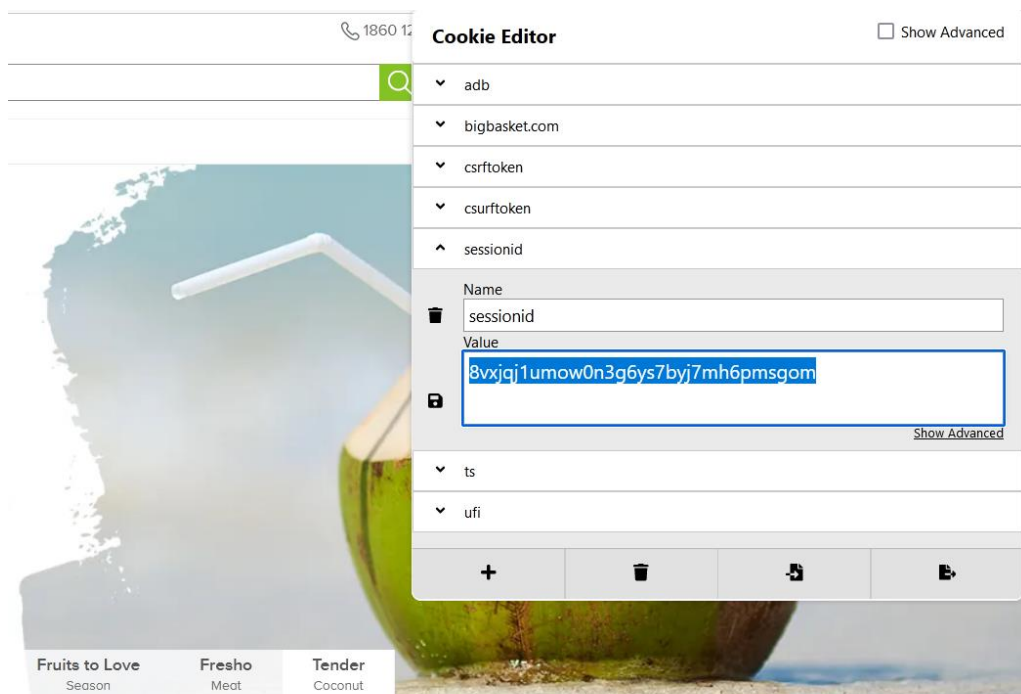
Result: Session ID can be restored. This is a vulnerability.

4. HTTP only flag and secure flag should be in enabled state



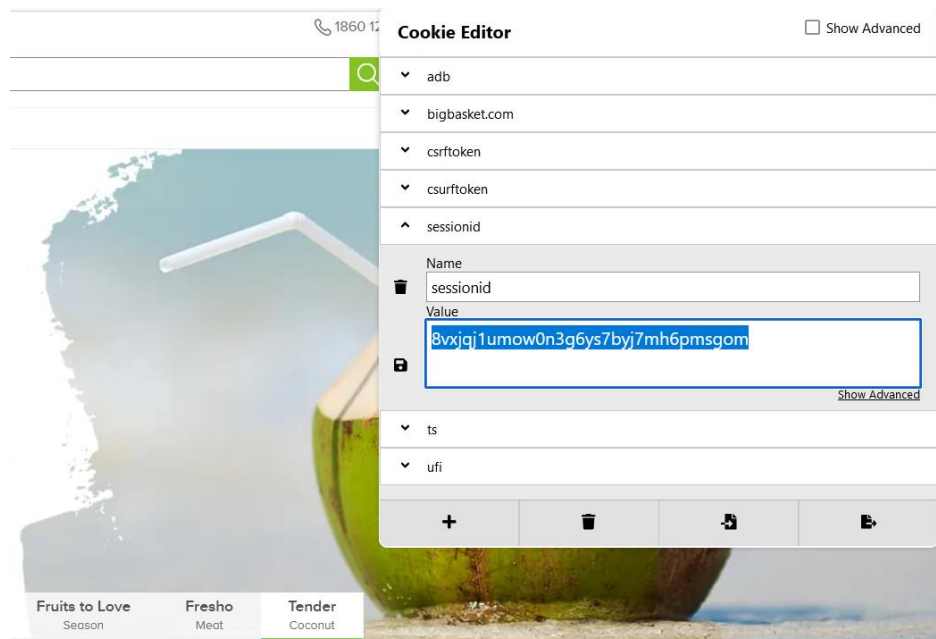
Result: Secure and Http only flags have been enabled.

5. Session ID must be some random value



Result: Session IDs are randomly generated. Not a vulnerability.

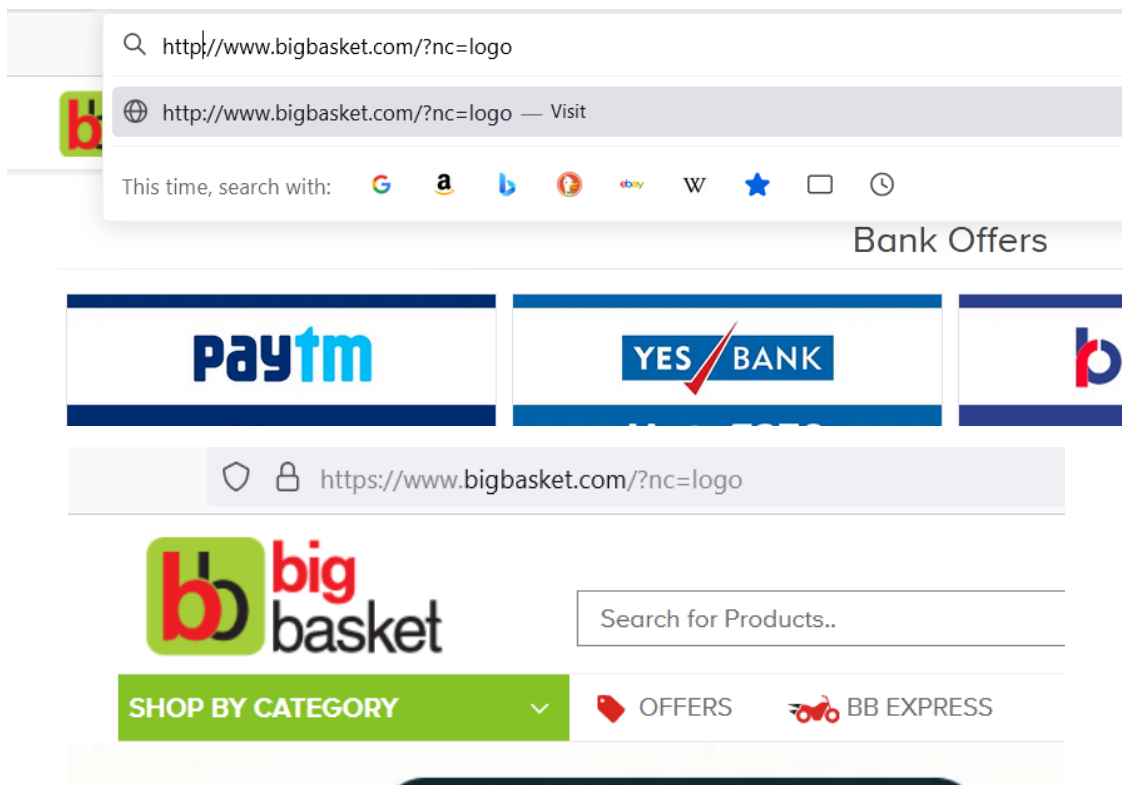
6. End user provided session IDs should not be accepted by the browser



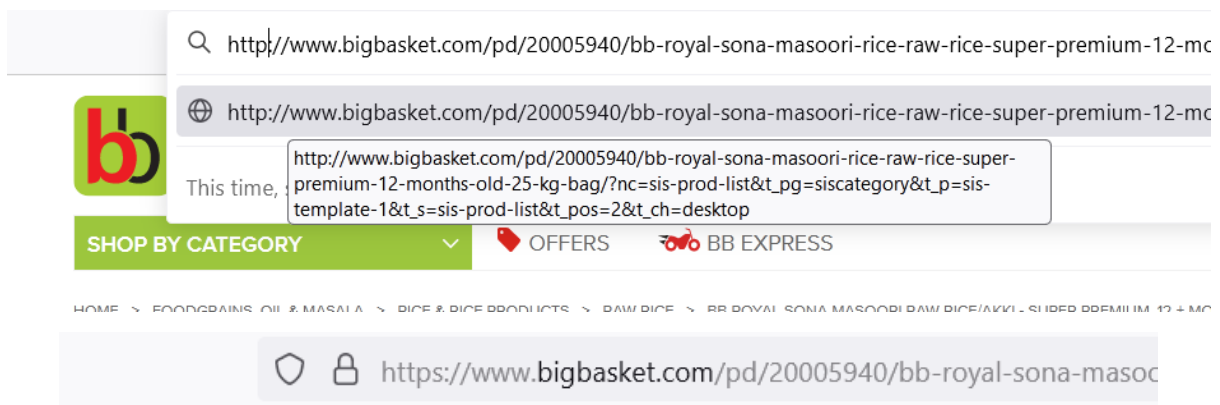
Result: End user provided session ID has been accepted by the browser. This is a vulnerability.

7. Strict transport policies must be implemented

Change the URL from https to http.

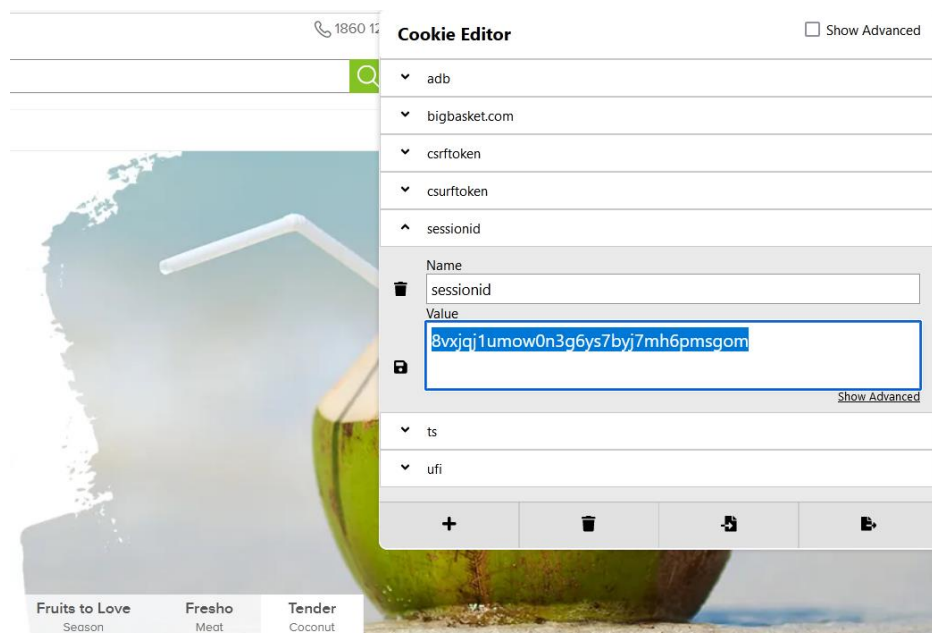


Open a different tab and change the URL from https to http again.



Result: Strict transport policies have been implemented.

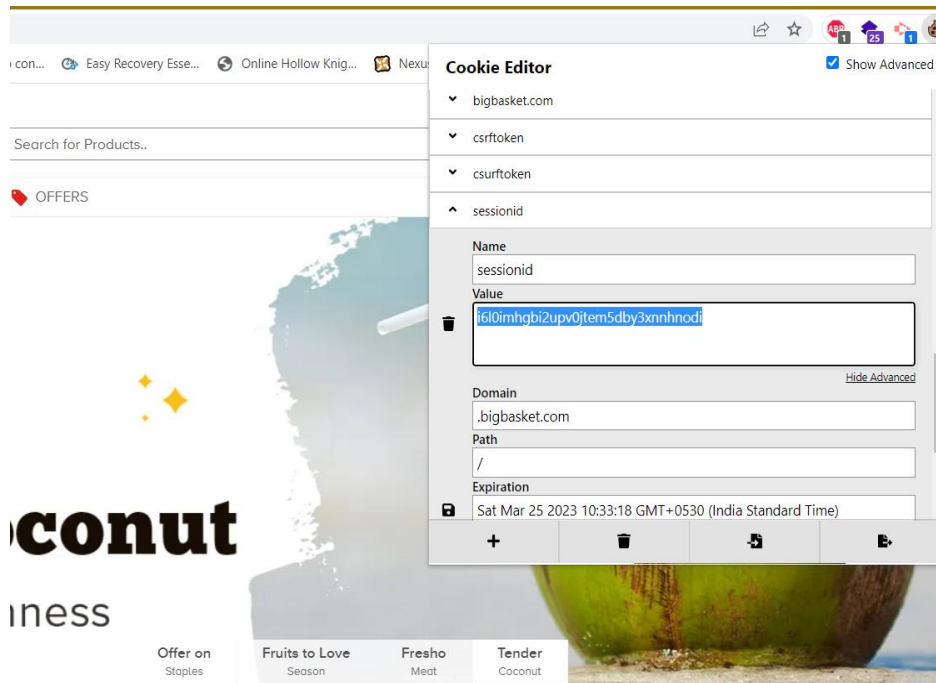
8. Weak session ID generation



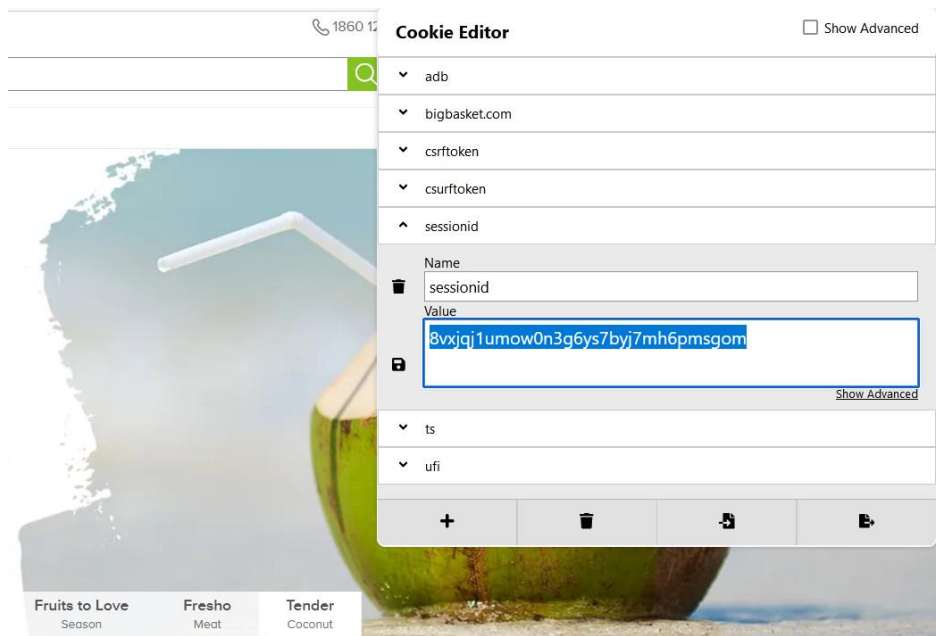
Result: Session IDs are randomly generated with high number of characters.
Session IDs are strong.

9. Do login for single user multiple times and check session ID generation

Attempt 1:



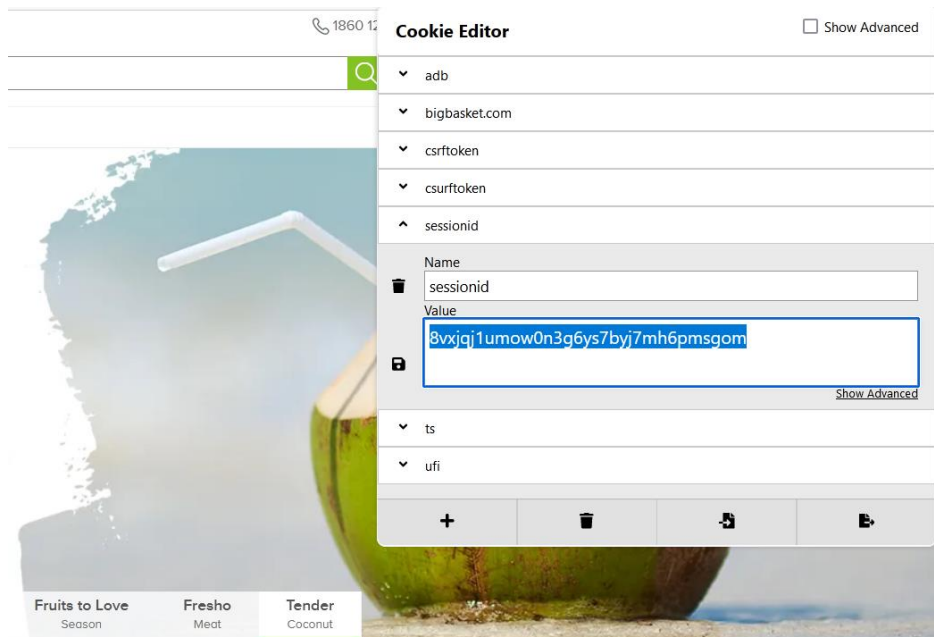
Attempt 2:



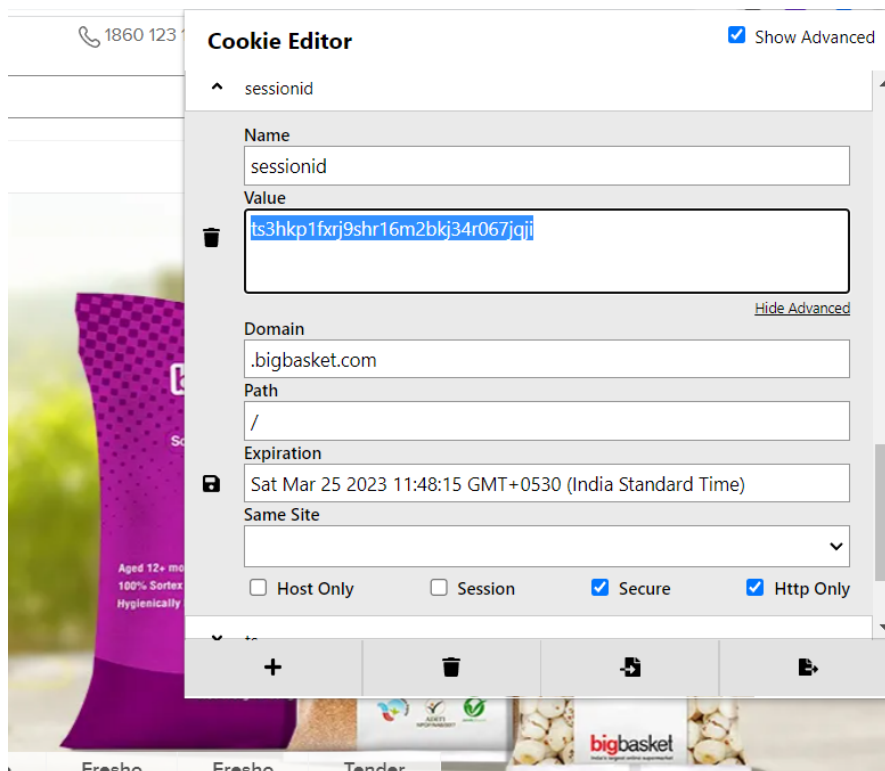
Result: Session IDs are randomly generated during each login.

10. Do login for multiple users and check session ID generation

User 1:

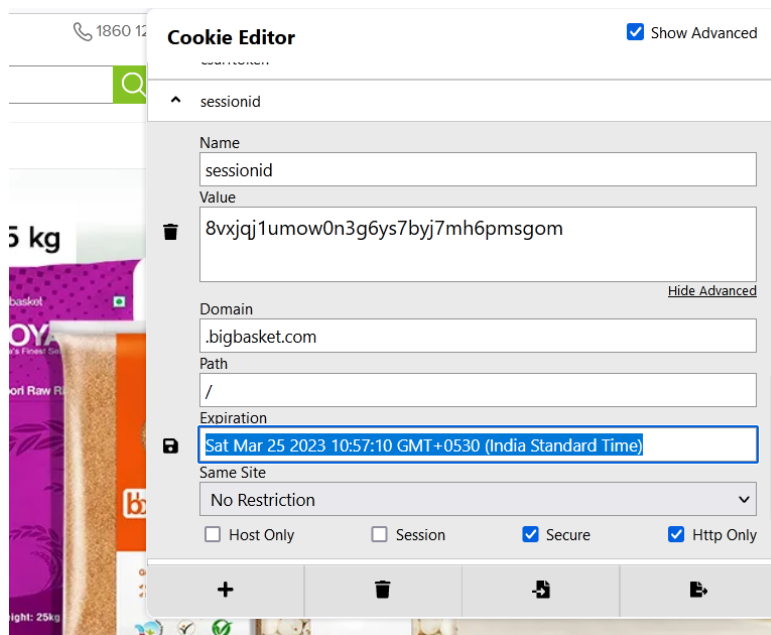


User 2:



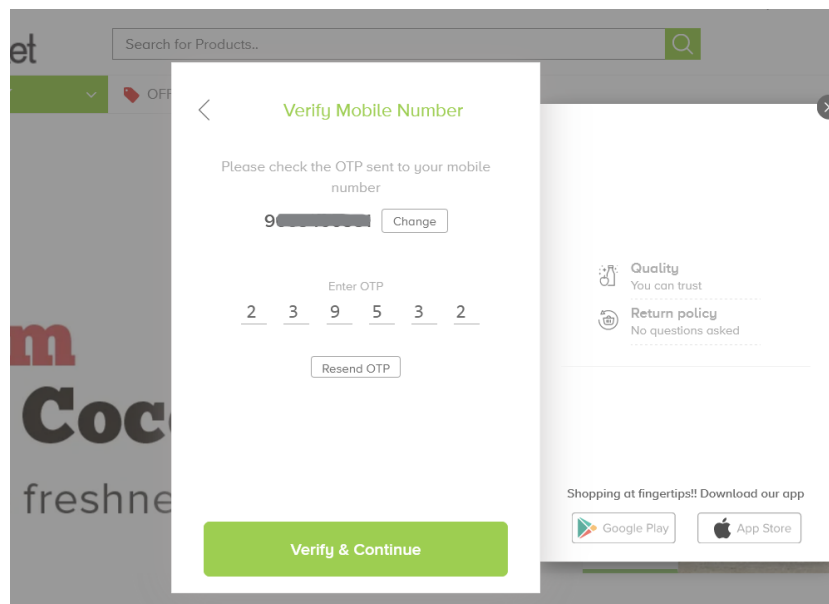
Result: Session IDs are randomly generated during each login.

11.Session timeout should be enabled



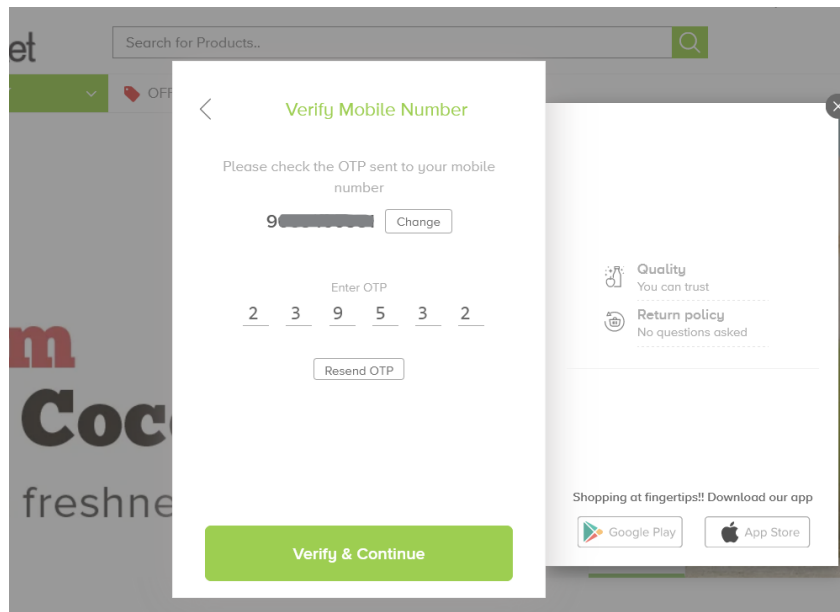
Result: Session timeout has been implemented.

12.Multifactor authentication should be implemented such as captcha, OTP, etc.



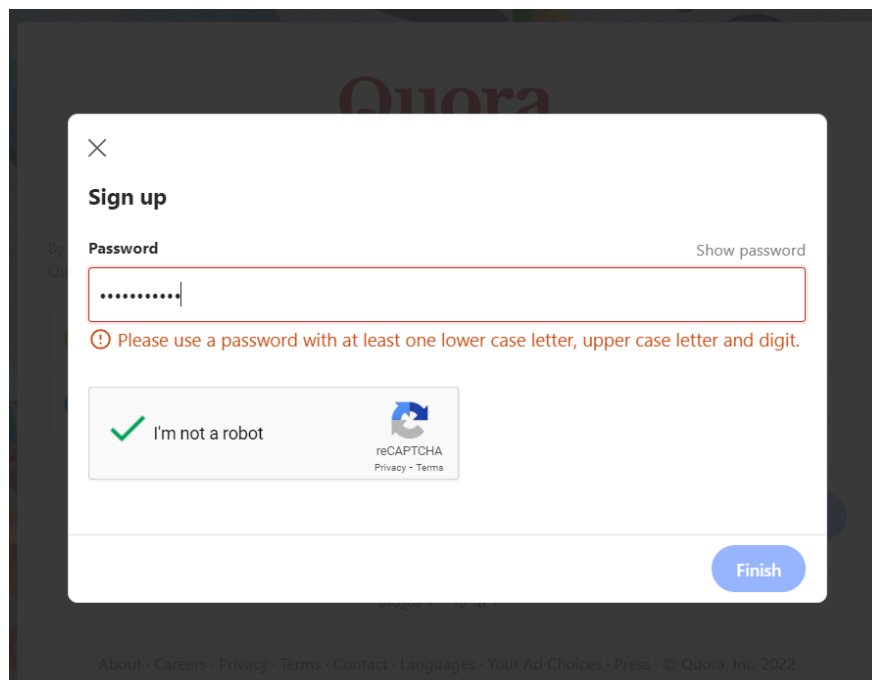
Result: OTP has been implemented for login purposes.

13.Copy paste clipboard action should be in disabled state in sensitive fields



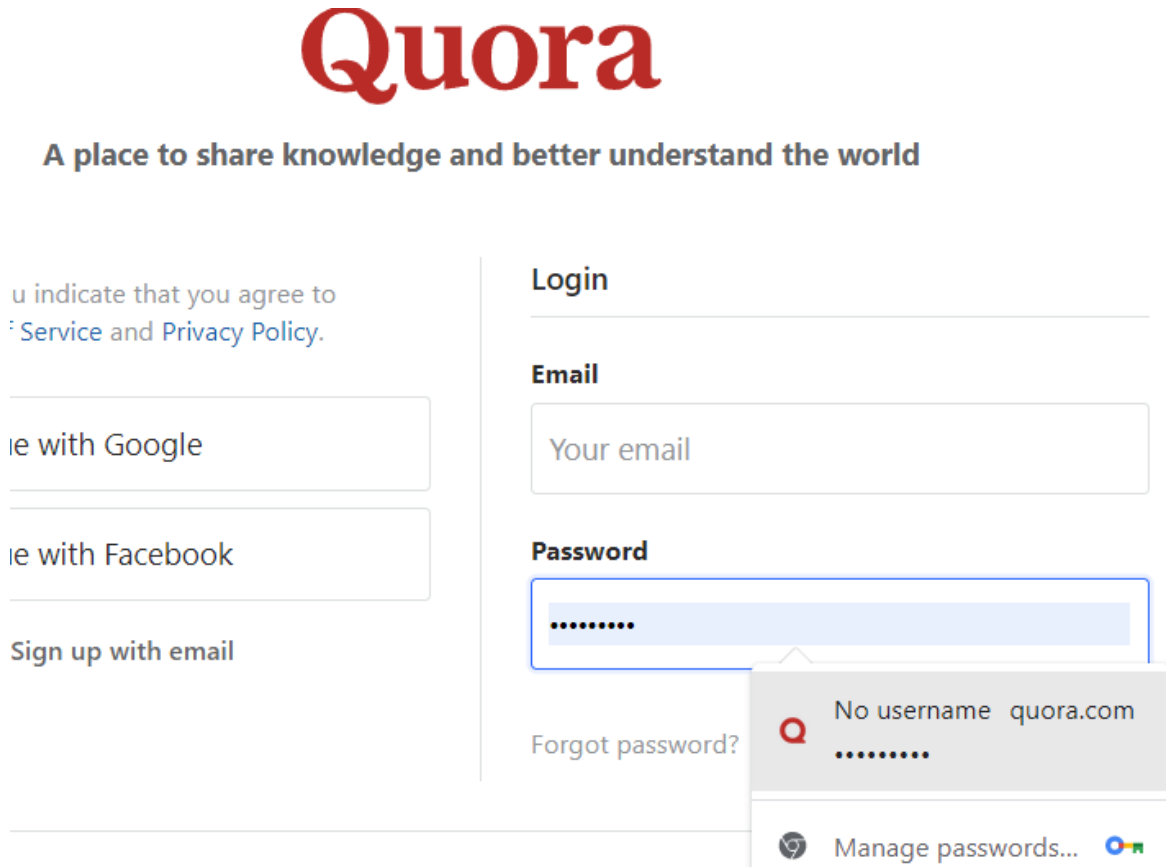
Result: Login page in this website has less sensitive fields and copying and pasting worked for OTP.

14.Strong password policies (Target – Quora.com)



Result: Strict password policies have been implemented

15. Autocomplete password should not be enabled (Target – Quora.com)



The image shows the Quora login page. The Quora logo is at the top, followed by the tagline "A place to share knowledge and better understand the world". On the left, there are links for "Sign up with Google", "Sign up with Facebook", and "Sign up with email". On the right, there is a "Login" section with fields for "Email" and "Password". The "Password" field is highlighted with a blue border, and a browser password manager popup is visible over it. The popup shows a red "Q" icon, the text "No username quora.com", and a masked password ".....". At the bottom of the popup, there is a link "Manage passwords..." with a key icon.

Quora

A place to share knowledge and better understand the world

By clicking, you indicate that you agree to our [Terms of Service](#) and [Privacy Policy](#).

Sign up with Google

Sign up with Facebook

Sign up with email

Login

Email

Your email

Password

.....

Forgot password?

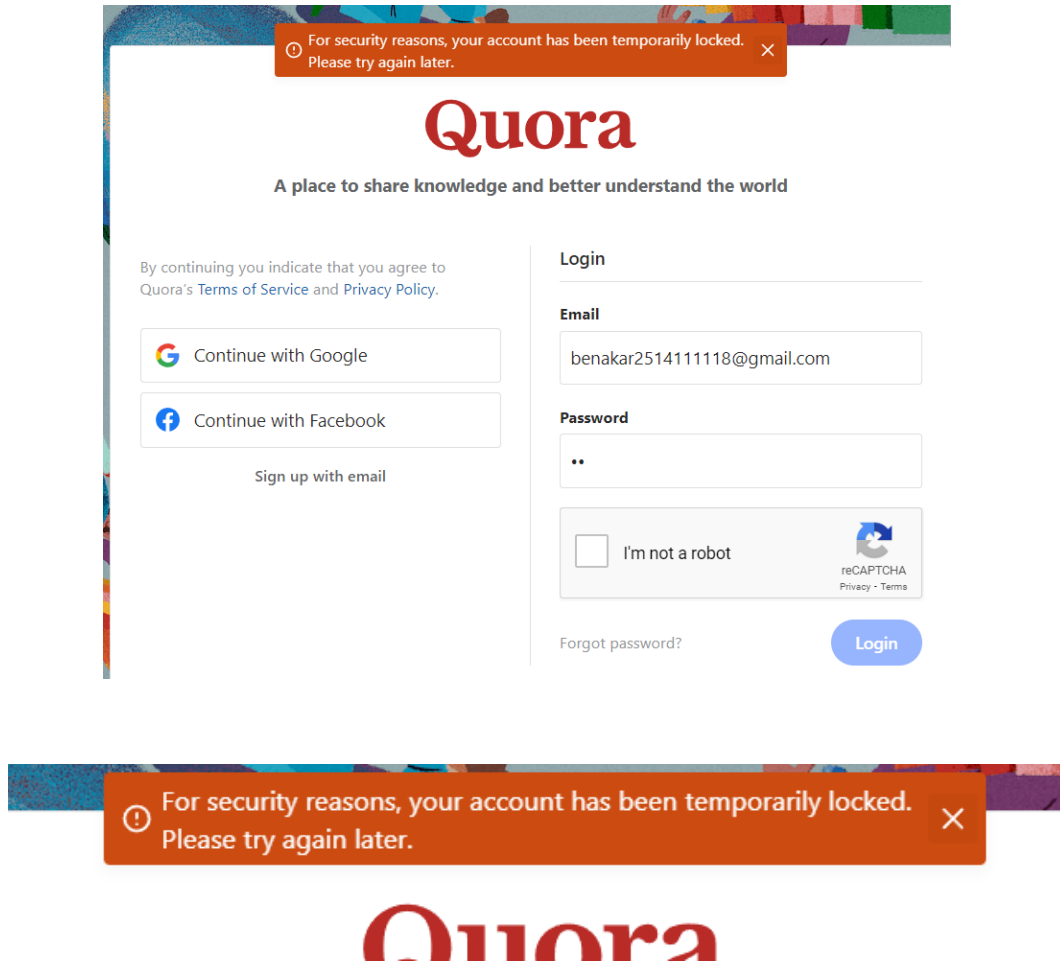
No username quora.com
.....

Manage passwords...

Result: Password was saved by the browser with user permission.
Autocomplete password is enabled.

16.Account lockout policy (Target – Quora.com)

Attempt to brute force the password with known email ID of user –



The image shows the Quora login page with a red banner at the top stating: "For security reasons, your account has been temporarily locked. Please try again later." The Quora logo is centered below the banner. The tagline "A place to share knowledge and better understand the world" is displayed. On the left, there are links for "Continue with Google", "Continue with Facebook", and "Sign up with email". On the right, the "Login" section includes fields for "Email" (containing "benakar2514111118@gmail.com") and "Password" (containing two dots). Below the password field is a reCAPTCHA "I'm not a robot" checkbox and a "Login" button. A "Forgot password?" link is also present. A second identical red banner is shown at the bottom of the page.

Result: Account was locked out after several attempts. Account lockout policy has been implemented.